

## Comparación Detallada: PTES vs OWASP

| Criterio                | PTES (Penetration Testing Execution Standard)                                                                                        | OWASP (Open Web Application Security Project)                                                           |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| Enfoque principal       | Metodología <b>integral</b> para pruebas de penetración (pentesting)                                                                 | Enfoque en <b>seguridad de aplicaciones web</b> , más preventivo que ofensivo                           |
| Ámbito de aplicación    | Infraestructura, redes, sistemas, aplicaciones, personal (ingeniería social)                                                         | Aplicaciones web y móviles, APIs, y prácticas de desarrollo seguro                                      |
| Estructura metodológica | Basada en <b>fases claramente definidas</b> del proceso de pentesting                                                                | Basada en <b>proyectos</b> y guías como OWASP Top 10, ASVS, MASVS                                       |
| Etapas/Fases            | 1. Pre-engagement2. Intelligence Gathering3. Threat Modeling4. Vulnerability Analysis5. Exploitation6. Post-Exploitation7. Reporting | Varía por proyecto, pero típicamente sigue un modelo de identificación de riesgos, testing y mitigación |
| Nivel de profundidad    | Muy técnico y profundo, busca comprometer sistemas reales                                                                            | Más orientado a la <b>evaluación y mejora de controles de seguridad</b>                                 |

|                                       |                                                                                |                                                                            |
|---------------------------------------|--------------------------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Audiencia objetivo</b>             | Pentesters, consultores de seguridad ofensiva                                  | Desarrolladores, arquitectos, auditores de aplicaciones                    |
| <b>Estándares/documentación</b>       | Unificado bajo un único documento PTES                                         | Diversos documentos: OWASP Top 10, ASVS, Testing Guide, Cheat Sheets, etc. |
| <b>Uso en la industria</b>            | Común en consultorías de seguridad y red teams                                 | Estándar de facto en desarrollo seguro y evaluación de apps web            |
| <b>Escenarios de uso típicos</b>      | Simulaciones de ataque, pruebas de caja negra/ gris/ blanca                    | Evaluación de seguridad en desarrollo SDLC, validación de aplicaciones web |
| <b>Herramientas sugeridas</b>         | Nmap, Metasploit, Burp, Empire, Cobalt Strike (depende del tipo de engagement) | ZAP, Dependency-Check, SonarQube, herramientas de SAST/DAST                |
| <b>Cobertura de Ingeniería Social</b> | Sí, como parte del modelo                                                      | Parcial o no cubierta directamente                                         |
| <b>Cobertura de Infraestructura</b>   | Alta: servidores, redes, sistemas operativos, firewalls                        | Limitada o nula, se enfoca más en la capa de aplicación                    |
| <b>Frecuencia de actualización</b>    | Menos frecuente, documento relativamente estático                              | Activo, con proyectos actualizados periódicamente                          |

|                                  |                                |                                                               |
|----------------------------------|--------------------------------|---------------------------------------------------------------|
| <b>Certificaciones asociadas</b> | Relevante para CEH, OSCP, PNPT | Relevante para OWASP-based certs, y referencia en CSSLP, GWEB |
| <b>Lenguaje</b>                  | Muy técnico                    | A veces técnico, a veces orientado a negocios/desarrolladores |

## Conclusión

- **PTES** es una **metodología ofensiva completa**, útil cuando se quiere llevar a cabo una **simulación de ataque estructurada**. Es ideal para pentesters y equipos red team.
- **OWASP**, por su parte, es una **guía de referencia para asegurar aplicaciones**, muy útil tanto en prevención como en validación de la seguridad de software.

Usa **PTES** cuando tu objetivo es realizar un **pentest completo y profesional**, incluyendo red, explotación y post-explotación.

Usa **OWASP** si necesitas **asegurar una aplicación web/móvil**, durante el ciclo de vida de desarrollo o en auditorías específicas.